

WEB APPLICATION SECURITY: XSS DETECTION

ANALYST

Solomon Waikumi

TARGET

Orion Health Systems Portal

VULNERABILITY

Reflected XSS (A03:2021)

ENGAGEMENT OVERVIEW

As a Junior Application Security Analyst at Orion Health Systems, I was tasked with auditing the search endpoints of our new patient health portal. The primary focus was identifying **Reflected Cross-Site Scripting (XSS)** vulnerabilities that could compromise patient browser sessions.

TECHNICAL IMPLEMENTATION

Automated Scanner Development: I developed `vuln_scanner.py` using the Python `requests` library to automate the injection of malicious payloads into search parameters.

Detection Logic: The script programmatically analyzes HTTP response bodies to determine if the injected script tags are reflected without proper sanitization or encoding.

AUTOMATED TESTING WORKFLOW

The scanner follows a rigorous logic to ensure accuracy and prevent false positives:

- Payload Iteration:** Loops through a list of diverse XSS payloads (e.g., `<script>alert(1)</script>`).
- Submission:** Sends GET/POST requests to the vulnerable endpoint.

3. **Reflection Analysis:** Checks if the exact payload string is present in the returned HTML.
4. **Exception Handling:** Implements try-except blocks to manage connection timeouts and broken URLs gracefully.

```
# Core Detection Logic Snippet
response = requests.get(url, params={'search': payload}, timeout=5)
if payload in response.text:
    print(f"[!] VULNERABLE: {payload} reflected.")
```

SECURE CODING RECOMMENDATIONS

To mitigate these findings, Orion Health Systems must implement **Context-Aware Output Encoding**. This ensures that user-supplied data is treated as plain text rather than executable code by the browser. Additionally, implementing a strong **Content Security Policy (CSP)** would provide a secondary layer of defense.

CONCLUSION

The automation of vulnerability scanning significantly reduces manual effort and increases the consistency of security audits. By integrating these scripts into the development lifecycle, we can identify and remediate injection flaws before they reach production.